

Manual 46 — Universal AI Governance Foundation

****Status:**** CONTROLLED DEVELOPMENT

****Version:**** 0.2.0-draft

****Controlled language:**** English

****Purpose:**** Universal, jurisdiction-aware AI-governance training and operating model.

1. Purpose and scope

Manual 46 is the universal foundation for the AI-governance training series. It is intentionally independent of any single employer, jurisdiction, regulator, standard, industry, model family, cloud platform, or AI architecture.

It teaches the common governance system that an organization can use to govern predictive AI, machine learning, generative AI, foundation models, RAG systems, embedded AI, and agentic AI across the complete lifecycle.

Later manuals specialize this foundation. Manual 47 is the first specialist training and covers the EU AI Act. Interview-specific questions, case drills and 30/60/90-day material are reserved for the final interview capstone rather than embedded in Manual 46.

2. Universal governance objective

AI governance is the system of decision rights, accountability, policies, processes, controls, evidence, oversight and assurance used to ensure that AI is selected, designed, acquired, developed, deployed, operated, changed and retired consistently with organizational objectives, risk appetite, law, security, privacy, data governance, human rights and stakeholder expectations.

The purpose is not to stop AI. The purpose is to make AI adoption demonstrably safe, lawful, controlled, useful and accountable.

3. Universal governance spine

****Accountability → Inventory → Classification → Risk/Impact Assessment → Data Governance → Security → Privacy → Human Oversight → Transparency → Testing/Validation → Documentation → Approval → Deployment → Monitoring → Incident/Change Management → Third-Party Governance → Evidence/Audit → Retirement → Continuous Improvement****

This spine is the common operating model for the entire series.

4. Core governance principles

1. ****Accountability is explicit.**** Every AI use case has an accountable business owner and identified technical ownership.
2. ****Governance is risk-based.**** Governance intensity increases with impact, autonomy, criticality, data sensitivity, scale, legal exposure and difficulty of reversal.

3. ****Govern the system, not only the model.**** Data, prompts, retrieval sources, tools, APIs, agents, humans, vendors, infrastructure and downstream actions are part of the governed system.
4. ****Lifecycle governance begins before production.**** Intake, classification and assessment precede approval.
5. ****Human oversight must be meaningful.**** A human reviewer needs competence, information, authority, time and a practical ability to intervene.
6. ****Security and privacy are native AI-governance concerns.**** They are not optional downstream reviews.
7. ****Evidence is required.**** An organization should be able to demonstrate what it decided, why, who approved it, what controls operated and how exceptions were handled.
8. ****Third-party AI does not outsource accountability.**** Providers may perform controls, but the adopting organization retains governance obligations appropriate to its role.
9. ****Monitoring is continuous.**** Drift, misuse, incidents, vendor changes, model changes, new tools, new data and regulatory changes can all trigger reassessment.
10. ****Governance should enable responsible innovation.**** Low-risk uses should not be burdened with controls designed for high-impact systems.

5. Roles and decision rights

A mature operating model distinguishes ownership, challenge and assurance.

First line

Business, product, engineering and operational teams own the AI use case, business outcome and day-to-day risk.

Second line

AI governance, enterprise risk, compliance, privacy, cybersecurity, data governance and model-risk functions establish policy, define control expectations, challenge decisions and monitor risk.

Third line

Internal audit or another independent assurance function assesses governance design and operating effectiveness without owning first- or second-line controls.

AI governance committee

The committee should have defined decision authority, escalation thresholds, quorum, conflict-of-interest handling and recorded decisions. Typical participation includes business leadership, AI/data, cybersecurity, privacy, legal/compliance, risk, product/engineering, procurement/third-party risk and, where appropriate, independent assurance observers.

6. AI inventory

An AI inventory is the control plane for governance. Minimum useful attributes include:

- unique system/use-case identifier;
- business and technical owners;
- intended purpose and users;
- model/provider/version;
- deployment geography and affected populations;

- model/system architecture;
- data categories and provenance;
- third-party dependencies;
- regulatory applicability;
- organizational risk tier;
- autonomy and tool/API access;
- human-oversight design;
- validation status;
- approval and exception records;
- monitoring metrics and thresholds;
- incident/change history;
- retirement status.

7. Classification and risk tiering

A universal classification process should consider at least:

- effect on health, safety, rights or access to essential opportunities/services;
- business criticality and financial exposure;
- autonomy and capacity to take consequential action;
- reversibility and availability of human intervention;
- personal, confidential, regulated or sensitive data;
- cybersecurity privilege and access to tools/systems;
- scale and number of affected users;
- external versus internal use;
- model/provider concentration risk;
- jurisdiction and regulatory classification;
- explainability and contestability requirements.

The classification result should determine assessment depth, required reviewers, validation rigor, approval authority and monitoring intensity.

8. Universal AI risk taxonomy

A practical enterprise taxonomy should cover:

- strategic and business risk;
- legal/regulatory risk;
- human-rights and societal impact;
- safety risk;
- model/performance risk;
- data quality and provenance risk;
- privacy risk;
- cybersecurity risk;
- misuse and abuse risk;
- bias/fairness risk;
- transparency/explainability risk;
- intellectual-property risk;
- third-party and supply-chain risk;
- operational resilience risk;

- agentic/autonomy risk;
- financial and fraud risk;
- reputational risk.

9. Lifecycle governance gates

****Intake → Inventory → Classification → Risk/Impact Assessment → Design/Acquisition Controls → Testing/Validation → Approval → Deployment → Monitoring → Change/Incident Management → Revalidation → Retirement****

A technical performance result alone is never sufficient approval evidence for a consequential AI system.

10. Data governance

AI governance should establish data lineage, lawful/authorized use, quality criteria, provenance, retention, minimization, access control, sensitive-data handling, training/evaluation separation where needed, RAG-source authorization and procedures for data correction or withdrawal.

11. Security governance

Security review should consider the full AI attack surface: model access, identity, APIs, secrets, training and inference pipelines, prompts, retrieval, plugins/tools, agent permissions, data exfiltration, model extraction, poisoning, prompt injection, indirect prompt injection, insecure output handling, supply-chain dependencies and monitoring.

12. Privacy governance

Privacy controls should address purpose, lawful basis or other applicable authorization, data minimization, sensitive data, retention, data-subject impacts, automated decision-making where relevant, cross-border flows, vendor processing and privacy impact assessment triggers.

13. Human oversight

Human oversight design should define:

- which decisions/actions require human review;
- who may approve or override;
- what information the reviewer receives;
- response-time requirements;
- escalation thresholds;
- mechanisms to stop or suspend the AI system;
- how override and intervention decisions are logged.

14. Testing, evaluation, verification and validation

Testing should be proportionate to risk and should address intended performance, foreseeable misuse, robustness, security, privacy, bias/fairness where relevant, explainability, data quality, edge cases, human factors, failure modes and residual risk.

Validation should be sufficiently independent from the development team for the risk level involved.

15. Generative-AI extensions

Generative AI adds control needs including:

- hallucination/confabulation evaluation;
- prompt and indirect-prompt injection controls;
- retrieval-source quality and authorization;
- sensitive-data leakage controls;
- output validation;
- content provenance/labeling where applicable;
- intellectual-property considerations;
- red teaming;
- guardrails and safe fallback behavior.

16. Agentic-AI extensions

Agent governance must control actions, not merely generated content. Key controls include:

- agent identity;
- bounded objectives;
- least-privilege authorization;
- tool/API allowlists;
- credential isolation;
- transaction/resource limits;
- human approval checkpoints;
- separation of duties;
- complete action logs;
- runtime anomaly detection;
- emergency disablement;
- multi-agent delegation controls;
- revalidation after changes to models, prompts, tools, permissions or data.

17. Third-party AI governance

Due diligence should evaluate provider governance, security, privacy, data-use terms, model limitations, subcontractors, change notification, incident notification, audit/assurance evidence, service continuity, exit strategy and contractual allocation of responsibilities.

18. Monitoring and continuous assurance

Monitoring should combine performance and risk indicators. Examples include drift, error rates, override rates, harmful-output rates, security events, policy exceptions, vendor changes, privacy events, unauthorized tool use, model/version changes, unresolved findings and overdue revalidation.

Threshold breaches should have predetermined escalation and response paths.

19. Incident and change management

An AI incident process should support detection, containment, evidence preservation, impact assessment, notification/escalation, remediation, lessons learned and revalidation.

Material changes to model, data, prompts, retrieval, tools, system purpose, user population, geography or autonomy should trigger formal change assessment.

20. Controls and evidence

Use the universal evidence chain:

****Requirement or Risk → Control Objective → Control Activity → Owner → Trigger/Frequency → Evidence → Test Procedure → Exception → Remediation → Residual-Risk Decision****

Useful evidence includes inventory records, classification decisions, impact assessments, threat models, data-flow diagrams, validation results, red-team reports, human-oversight procedures, approval records, vendor due diligence, contract clauses, monitoring dashboards, incident records, exception decisions and independent-assurance results.

21. Framework interoperability

Manual 46 is framework-neutral but compatible with major governance systems, including:

- EU AI Act;
- ISO/IEC 42001;
- NIST AI RMF and NIST AI 600-1;
- Singapore Model AI Governance Framework and AI Verify;
- OECD AI Principles;
- sector and jurisdiction-specific requirements.

Alignment to a voluntary framework does not, by itself, prove legal compliance or certification.

22. Training outcome

A learner completing Manual 46 should be able to:

11. establish an AI governance operating model;
12. design an AI inventory;
13. classify risk and autonomy;
14. run lifecycle risk and impact assessments;
15. establish control gates and approval authority;
16. govern GenAI and agentic AI extensions;
17. manage vendors and supply-chain risks;
18. design evidence and assurance;
19. monitor AI risk continuously; and
20. map the universal model to specialist legal and framework requirements.

23. Controlled series sequence

21. ****Manual 46 — Universal AI Governance Foundation****
22. ****Manual 47 — EU AI Act Training & Operationalization****
23. ****Manual 48 — Singapore AI Governance****
24. ****Manual 49 — NIST AI RMF + NIST AI 600-1****
25. ****Manual 50 — Global AI Governance Crosswalk****
26. ****Manual 51 — Agentic AI Governance, Security, Identity & Human Accountability****

27. Subsequent specialist manuals: GenAI/LLM risk, AI cybersecurity, privacy/data governance, model risk, third-party AI, operating model/RACI, lifecycle governance, classification, impact assessment, controls/evidence, monitoring, incidents, audit/assurance, OECD, UNESCO, executive scenarios and interview capstone.

24. Publication gates

- ☐ Authoritative-source verification complete.
- ☐ Controlled-English substantive review complete.
- ☐ Cross-framework consistency review complete.
- ☐ AI/security/privacy technical review complete.
- ☐ Copyright/licensed-source controls complete.
- ☐ Accessibility review complete.
- ☐ Localization terminology prepared.
- ☐ DOCX/PDF generation complete if publication artifacts are produced.
- ☐ Visible-page and text validation complete for every PDF.
- ☐ Release manifest/provenance/checksums complete.
- ☐ Repository/workflow security QA complete.
- ☐ Standing release authorization satisfied under the canonical equation; no separate generic final approval prompt.

****Fail-closed rule:**** Manual 46 remains controlled development until every applicable release gate is satisfied.

Manual 46 — Universal AI Governance Foundation

Controlled Training Modules

****Status:**** CONTROLLED DEVELOPMENT

****Relationship:**** Substantive training companion to the Manual 46 controlled-English master.

Learning design

Manual 46 is intended to create practitioner capability, not memorization. Each module follows a repeatable pattern:

****Concept → Decision → Control → Evidence → Challenge → Exercise****

A learner should be able to apply the governance model to predictive AI, machine learning, generative AI, RAG, foundation-model services, embedded AI and agentic systems without depending on one legal regime or framework.

Module 1 — Establish the governance mandate

Objective

Define why the organization governs AI and where accountability sits.

Practitioner tasks

- Identify executive sponsorship.
- Define AI-governance scope and boundaries.

- Connect AI governance to enterprise risk appetite.
- Establish decision rights and escalation authority.
- Distinguish first-line ownership, second-line oversight and third-line assurance.

Required evidence

- AI governance charter.
- Approved policy hierarchy.
- Committee terms of reference.
- Decision-rights matrix.
- Risk-appetite linkage.

Challenge questions

- Who can stop deployment?
- Who may accept residual AI risk?
- What happens when business and control functions disagree?
- Is internal audit independent from control ownership?

Exercise

Design a governance charter for an organization introducing AI across HR, customer service, software development and finance.

Module 2 — Build the AI inventory

Objective

Create a reliable system of record for governed AI.

Practitioner tasks

- Define what qualifies as an AI use case or AI system.
- Identify shadow AI and embedded vendor AI.
- Record business and technical ownership.
- Capture models, providers, data, tools, integrations and deployment geography.
- Track lifecycle and approval state.

Minimum inventory record

- unique identifier;
- business purpose;
- business owner;
- technical owner;
- model/provider/version;
- deployment environment;
- users and affected populations;
- data categories and provenance;
- third parties;
- jurisdictional footprint;
- risk tier;
- autonomy level;
- validation state;
- human oversight;

- approval state;
- monitoring state;
- last material change;
- retirement state.

Evidence test

A reviewer should be able to identify every production AI use case and its accountable owner without relying on tribal knowledge.

Module 3 — Classify risk, impact and autonomy

Objective

Determine governance intensity before detailed controls are selected.

Classification dimensions

- potential impact on people and rights;
- health and safety impact;
- business criticality;
- financial exposure;
- data sensitivity;
- cybersecurity privilege;
- autonomy;
- reversibility;
- scale;
- external versus internal use;
- legal/regulatory classification;
- dependency and concentration risk;
- transparency/contestability need.

Practical outcome

The classification determines:

- assessment depth;
- required control functions;
- validation independence;
- approval authority;
- human-oversight requirements;
- monitoring frequency;
- revalidation triggers.

Anti-pattern

Do not classify an AI system as low risk merely because it is purchased from a major vendor.

Module 4 — Perform AI risk and impact assessment

Objective

Translate context into explicit risks and treatment decisions.

Assessment domains

- strategic/business;
- legal/regulatory;
- human-rights and societal impact;
- safety;
- model performance;
- data quality/provenance;
- privacy;
- cybersecurity;
- misuse/abuse;
- bias/fairness where relevant;
- transparency/explainability;
- intellectual property;
- third-party/supply chain;
- resilience;
- autonomy/autentic action;
- fraud/financial;
- reputation.

Assessment output

For each material risk record:

Scenario → Cause → Impact → Inherent Risk → Control → Residual Risk → Owner → Decision

Quality criterion

Risk statements must describe plausible adverse outcomes, not vague labels such as “AI risk.”

Module 5 — Govern data and knowledge

Objective

Ensure AI data and knowledge sources are authorized, traceable and fit for purpose.

Control topics

- lineage and provenance;
- authorized purpose;
- quality and representativeness;
- minimization;
- sensitive-data handling;
- retention and deletion;
- training/evaluation separation where relevant;
- RAG corpus approval;
- retrieval authorization;
- correction and withdrawal;
- vendor data-use terms.

GenAI extension

Treat prompts, context windows, vector stores, retrieval indexes, embeddings and fine-tuning datasets as governed information assets where appropriate.

Module 6 — Secure the AI system

Objective

Integrate security throughout the AI lifecycle.

Threat surfaces

- model endpoints;
- APIs;
- identity and authorization;
- secrets and credentials;
- training/inference pipelines;
- prompts and system instructions;
- retrieval sources;
- tool/plugin connections;
- agent permissions;
- model and dependency supply chains;
- telemetry and logs.

Security outcomes

- least privilege;
- secure secrets handling;
- input/output validation;
- prompt-injection resistance;
- data-exfiltration prevention;
- dependency integrity;
- attack detection;
- containment and recovery.

Module 7 — Design meaningful human oversight

Objective

Avoid ceremonial “human in the loop” claims.

Oversight test

A human overseer must have:

28. sufficient information;
29. relevant competence;
30. practical time to review;
31. authority to intervene;
32. a functioning intervention mechanism.

Controls

- defined approval checkpoints;

- override authority;
- escalation criteria;
- stop/suspend capability;
- override logging;
- reviewer training;
- workload/capacity controls.

Failure mode

A human who is expected to approve thousands of AI decisions without meaningful review capacity is not an effective control.

Module 8 — Test, evaluate, verify and validate

Objective

Demonstrate that the AI system is fit for its intended use and controlled for foreseeable failure modes.

Test domains

- intended performance;
- robustness;
- edge cases;
- misuse/abuse;
- security;
- privacy;
- fairness where relevant;
- explainability;
- human factors;
- failure recovery;
- GenAI factuality/confabulation;
- RAG retrieval quality;
- agent action boundaries.

Validation independence

Independence should increase with materiality. High-impact systems require meaningful challenge beyond the development team.

Module 9 — Establish lifecycle approval gates

Objective

Convert governance from advice into enforceable decisions.

Core gates

Intake → Inventory → Classification → Assessment → Design/Acquisition Review → Validation → Approval → Deployment → Monitoring → Change/Revalidation → Retirement

Gate decision types

- approve;
- approve with conditions;

- reject;
- defer pending evidence;
- exception with time-bound risk acceptance;
- suspend;
- retire.

Evidence requirement

Each decision records the approver, date, scope, conditions, evidence considered and residual-risk disposition.

Module 10 — Govern third-party AI

Objective

Manage AI risk even when the organization does not build the model.

Due-diligence areas

- provider governance;
- security and privacy;
- data use;
- model limitations;
- subcontractors;
- geographic processing;
- change notification;
- incident notification;
- assurance evidence;
- service continuity;
- contractual allocation of responsibility;
- exit and portability.

Key principle

Vendor adoption changes the control allocation; it does not eliminate organizational accountability.

Module 11 — Govern generative AI

Objective

Extend the universal model for probabilistic content generation and retrieval-based systems.

Additional control areas

- hallucination/confabulation;
- prompt injection and indirect injection;
- sensitive-data leakage;
- retrieval governance;
- output verification;
- content provenance and labeling where applicable;
- intellectual-property considerations;
- red teaming;
- guardrails;

- safe fallback behavior.

Module 12 — Govern agentic AI

Objective

Control systems that can choose and execute actions.

Core control areas

- agent identity;
- bounded purpose;
- authorization;
- least privilege;
- tool/API allowlists;
- credential isolation;
- transaction/resource limits;
- human approval checkpoints;
- separation of duties;
- action provenance;
- runtime monitoring;
- emergency stop capability;
- multi-agent delegation controls;
- revalidation after model, prompt, tool, permission or data changes.

Practitioner rule

For agents, evaluate both ****what the system can say**** and ****what the system can do****.

Module 13 — Monitor AI continuously

Objective

Detect when assumptions, performance or risk conditions change.

Example KRIs/KPIs

- performance drift;
- error/failure rates;
- override rates;
- harmful-output rates;
- security events;
- privacy events;
- unauthorized tool use;
- exception volume;
- unresolved findings;
- vendor/model-version changes;
- overdue revalidation;
- incident recurrence.

Monitoring design

Every monitored metric should have an owner, threshold, cadence, evidence source and predefined response.

Module 14 — Manage incidents and change

Objective

Ensure AI failures and material changes trigger controlled response.

Incident lifecycle

Detect → Contain → Preserve Evidence → Assess Impact → Escalate/Notify → Remediate → Validate → Learn

Material-change triggers

- model change;
- model-version change;
- provider change;
- prompt/system-instruction change;
- data-source change;
- retrieval change;
- tool/API addition;
- permission increase;
- new user population;
- new geography;
- new business purpose;
- autonomy increase.

Module 15 — Build evidence and assurance

Objective

Make governance demonstrable.

Universal evidence chain

Requirement or Risk → Control Objective → Control Activity → Owner → Trigger/Frequency → Evidence → Test Procedure → Exception → Remediation → Residual-Risk Decision

Assurance levels

- first-line self-assessment;
- second-line challenge/testing;
- independent validation;
- internal audit;
- external assurance where appropriate.

Completion standard

A learner can defend not only that a control exists, but that it operated and produced evidence.

Module 16 — Executive and board governance

Objective

Translate detailed AI control data into decision-useful governance information.

Executive reporting themes

- inventory growth and materiality;
- high-risk/high-impact use cases;
- exceptions and residual-risk acceptances;
- overdue validation/revalidation;
- incidents;
- vendor concentration;
- regulatory exposure;
- control failures;
- emerging GenAI/agentic risk;
- risk trends against appetite.

Board-level question

Can leadership determine where the organization is taking material AI risk and whether that risk remains within appetite?

Capstone exercise

Given a proposed customer-facing AI assistant that uses a third-party foundation model, RAG over internal knowledge, personal customer data and tools capable of modifying customer records:

33. Define the system boundary.
34. Identify accountable owners.
35. Populate the inventory record.
36. Classify impact and autonomy.
37. Identify material risks.
38. Define security/privacy/data controls.
39. Define human oversight.
40. Design validation evidence.
41. Define approval gates.
42. Define runtime monitoring.
43. Define incident/change triggers.
44. Identify third-party requirements.
45. Specify evidence retained.
46. State conditions under which deployment should be suspended.

The exercise should be answerable using the universal model without relying on any one jurisdiction or standard.

Manual 46 — Universal AI Governance Foundation

Practical Scenarios and Tabletop Exercises

****Status:**** CONTROLLED DEVELOPMENT

These scenarios test whether the learner can apply the universal governance model without depending on one law, one standard or one vendor.

Scenario 1 — Internal GenAI assistant

An enterprise introduces a generative-AI assistant for employees. It can summarize documents, draft responses and answer questions using internal knowledge.

Required analysis: inventory and ownership; data classification; prompt and retrieval controls; privacy/confidentiality risk; output validation; access control; monitoring; vendor/provider obligations; acceptable-use controls; incident escalation.

Minimum evidence: approved use-case record; data-flow diagram; security/privacy assessment; RAG source approval; acceptable-use policy; validation results; monitoring design; approval record.

Scenario 2 — Customer-facing AI decision support

A customer-facing AI system recommends products or services that materially affect customer outcomes.

Required analysis: consequential impact; explainability and contestability; bias/fairness where relevant; human oversight; model validation; customer transparency; complaint handling; change/revalidation triggers.

Governance decision: determine whether the system can operate autonomously, requires human review, or should remain advisory only.

Scenario 3 — HR screening tool

A third-party AI service ranks applicants for employment decisions.

Required analysis: affected population; vendor governance; data provenance; discrimination/fairness risk; human oversight; transparency; legal applicability screening; validation independence; evidence retained for decisions and challenges.

Key lesson: a vendor assurance statement does not replace the deploying organization's own risk assessment and governance obligations.

Scenario 4 — RAG over sensitive enterprise records

A RAG application retrieves information from internal legal, financial, HR and customer repositories.

Required analysis: repository authorization; least-privilege retrieval; row/document-level permissions; embeddings/vector-store controls; source freshness; data leakage; prompt injection; logging; source attribution; retention; incident containment.

Scenario 5 — Autonomous service agent

An AI agent may read customer records, create tickets, modify account attributes and initiate limited financial adjustments.

Required analysis: agent identity; authentication; authorization; bounded purpose; tool allowlists; transaction limits; human approval checkpoints; separation of duties; action provenance; runtime anomaly detection; emergency stop; incident forensics; revalidation after permission/tool changes.

Critical question: what can the agent do that a human would normally need explicit authority to do?

Scenario 6 — AI coding assistant

Developers use an AI coding assistant with repository context and code-generation capability.

Required analysis: source-code confidentiality; dependency risk; insecure code generation; secrets exposure; license/IP issues; code review; security testing; generated-code provenance; privileged repository access; model/provider data use.

Scenario 7 — High-volume low-impact automation

An AI classifier routes routine internal support tickets.

Required analysis: risk proportionality; operational resilience; false routing; monitoring; change controls; data sensitivity.

Key lesson: universal governance should not impose high-impact controls on low-impact use cases without justification.

Scenario 8 — Material vendor model change

A cloud AI provider changes the underlying model version used by a production application.

Required analysis: contractual notification; change materiality; regression testing; risk reassessment; validation scope; user impact; rollback; approval; evidence.

Scenario 9 — AI incident

A production assistant discloses confidential information and logs show repeated indirect prompt-injection attempts.

Tabletop response: detect; contain; preserve evidence; determine affected data/users; disable risky integrations if needed; assess legal/regulatory notification requirements; remediate; test; revalidate; document lessons learned; update threat model and controls.

Scenario 10 — Board challenge

The board asks: “Where are we taking the most AI risk, and how do we know controls are working?”

A strong response must synthesize inventory, risk tier, exceptions, validation status, incidents, vendor concentration, KRIs, overdue remediation and residual-risk decisions rather than reporting model counts alone.

Scoring rubric

For each scenario, score 0–2 on each dimension:

- 47. accountable ownership;
- 48. inventory/system boundary;
- 49. classification;
- 50. risk/impact assessment;
- 51. security/privacy/data controls;

- 52. human oversight;
- 53. testing/validation;
- 54. approval/evidence;
- 55. monitoring/change;
- 56. incident/escalation.

Maximum score: 20. A score below 14 indicates material gaps in operational governance reasoning.

Manual 46 — Universal AI Governance Foundation

Control and Evidence Workbook

****Status:**** CONTROLLED DEVELOPMENT

This workbook converts the universal AI-governance model into operational control design and assurance evidence.

1. Control record template

For each control, record:

- Control ID
- Risk or requirement addressed
- Control objective
- Control activity
- Accountable owner
- Operator
- Trigger or frequency
- Systems/use cases in scope
- Evidence generated
- Test procedure
- Exception process
- Remediation owner/date
- Residual-risk decision

2. Minimum universal control domains

GOV-01 — AI accountability

Objective: every governed AI use case has an accountable business owner and technical owner.

Evidence: inventory record, ownership acceptance, committee escalation path.

INV-01 — AI inventory completeness

Objective: production and material pre-production AI systems are recorded in a governed inventory.

Evidence: inventory extract, reconciliation results, shadow-AI discovery records.

CLS-01 — Risk and autonomy classification

Objective: governance intensity is determined from documented risk, impact and autonomy criteria.

Evidence: classification worksheet, tier decision, approver.

RSK-01 — AI risk/impact assessment

Objective: material risks are identified, evaluated, treated and accepted before deployment.

Evidence: risk assessment, impact assessment, treatment plan, residual-risk acceptance.

DAT-01 — Data and knowledge governance

Objective: AI data and knowledge sources are authorized, traceable and appropriate for intended use.

Evidence: lineage, provenance, source approvals, retention rules, RAG corpus register.

SEC-01 — AI security review

Objective: AI-specific and conventional security threats are identified and controlled.

Evidence: threat model, architecture review, test results, remediation records.

PRV-01 — Privacy assessment

Objective: personal and sensitive data use is reviewed and controlled according to applicable requirements.

Evidence: privacy assessment/DPIA where applicable, data-flow map, minimization and retention decisions.

HUM-01 — Meaningful human oversight

Objective: required human intervention is practical, authorized and testable.

Evidence: oversight procedure, reviewer authority, training, override logs, stop/suspend procedure.

VAL-01 — Testing and validation

Objective: the system is validated for intended use and foreseeable material failure modes before approval.

Evidence: test plan, validation report, findings, independent challenge where required.

APP-01 — Deployment approval

Objective: production deployment occurs only after required governance gates are satisfied.

Evidence: approval record, conditions, exceptions, residual-risk decision.

TPR-01 — Third-party AI governance

Objective: provider controls and dependencies are assessed and contractually governed.

Evidence: due diligence, assurance reports, contract clauses, provider change/incident obligations.

MON-01 — Continuous monitoring

Objective: performance and risk indicators are monitored against defined thresholds.

Evidence: dashboards, alert logs, threshold definitions, escalations.

CHG-01 — Material change and revalidation

Objective: material changes trigger proportionate reassessment and revalidation.

Evidence: change record, materiality assessment, regression/validation results, reapproval.

INC-01 — AI incident management

Objective: AI incidents are detected, contained, investigated, escalated and remediated.

Evidence: incident record, preserved logs, impact assessment, notifications, corrective actions.

AUD-01 — Governance evidence and assurance

Objective: AI governance decisions and control operation are independently testable.

Evidence: audit trail, control test results, findings, remediation and assurance reports.

RET-01 — Retirement and decommissioning

Objective: retired AI systems are disabled, dependencies removed, data handled appropriately and evidence retained.

Evidence: retirement approval, access removal, archive/retention record, inventory closure.

3. Control design quality test

A control is not complete merely because a policy says it should happen. A testable control identifies:

****who does what, when, using what criteria, producing what evidence, and what happens when the result fails.****

4. Evidence sufficiency test

Evidence should support four questions:

- 57. Was the control designed appropriately?
- 58. Did it operate when required?
- 59. Was the result reviewed and exceptions handled?
- 60. Can an independent reviewer reconstruct the decision?

5. Exception record

Each exception should state:

- requested deviation;
- affected system/use case;
- reason;
- risk created;
- compensating controls;
- approving authority;
- expiration date;
- monitoring requirements;
- remediation/closure condition.

Open-ended exceptions without expiration or review are a governance anti-pattern.

6. Residual-risk acceptance

Residual-risk acceptance should identify the specific residual risk, affected business objective, evidence considered, risk owner, authority level, acceptance period and reassessment trigger.

7. Assurance test worksheet

For each sampled AI system:

61. Verify inventory completeness.
62. Verify ownership.
63. Reperform classification logic.
64. Confirm required assessments occurred.
65. Trace material risks to controls.
66. Inspect validation evidence.
67. Confirm approval authority.
68. Inspect monitoring evidence.
69. Inspect material changes and revalidation.
70. Inspect incidents/exceptions.
71. Confirm third-party obligations where applicable.
72. Confirm evidence retention and auditability.

8. Executive evidence pack

A concise executive evidence pack should include:

- inventory by risk tier;
- material/high-impact systems;
- approval/validation status;
- residual-risk acceptances;
- exceptions nearing expiry;
- unresolved high-severity findings;
- AI incidents and trends;
- third-party concentration;
- overdue revalidation;
- key risk indicators against thresholds.

9. Completion criterion

The learner should be able to take any AI use case and produce a traceable chain from business purpose through risk, controls, evidence, monitoring and residual-risk decision.